

A. Assignment Information

Particular	Details
Department	Artificial Intelligence and Data Science
Programme	UG B.Tech
Course Code & Course Name	ITA1408 – Ethical Hacking
Academic Year / Batch	2026–2027
Faculty Name	Dr S Parthiban
Assignment Title	Design, simulate, secure and validate a cybersecurity architecture for a smart healthcare centre using CICIoMT2024
Maximum Marks	100
Course Outcome(s) – CO	CO3: Examine network services through port scanning, ping sweeps and enumeration to surface vulnerabilities across operating systems. CO4: Apply network security testing methods to web-server, web-application and wireless-network assessment inside an authorized Kali Linux lab. CO5: Assess vulnerabilities in Windows and Linux hosts and judge security weaknesses using suitable ethical-hacking tools.
Bloom's Taxonomy Level	L6 – Create
SDG Mapping	SDG 9 – Industry, Innovation and Infrastructure
Industry / Societal Relevance	Safeguarding connected medical devices, patient data and clinical services from compromise

B. Assignment Problem

A modern smart healthcare facility ties together bedside monitors, wearable sensors, clinician workstations, a mix of Windows and Linux servers, a wireless IoMT network, a web-based

electronic health record (EHR) portal, and clinicians who connect remotely. Because so many device types and access paths are interconnected, the attack surface grows accordingly, which is why a layered, defence-in-depth security posture is required rather than any single control.

This individual assignment uses the publicly released CICIoMT2024 dataset to study what normal versus malicious healthcare-IoT traffic looks like, extract the attack behaviours that matter most, and turn those findings into a workable cybersecurity architecture. All hands-on testing is confined to an authorized, isolated virtual lab and limited to non-destructive techniques throughout.

The resulting design brings together network segmentation, firewall and access-control policy, multifactor authentication, role-based access control, encryption, secured wireless communication, intrusion detection, centralized logging, patch management, and backup/recovery. Its effectiveness is judged against measurable indicators — exposed services, attack-detection rate, false-alarm rate, response time, network availability and resource utilization.

Objectives

- Identify what a connected healthcare environment needs from a security standpoint.
- Study CICIoMT2024 benign and malicious traffic to surface the attack patterns that matter.
- Carry out controlled network, web, wireless and OS-level security checks with Kali Linux and supporting tools.
- Rank vulnerabilities by their likelihood and their impact on patient safety, confidentiality, integrity and availability.
- Produce a single integrated secure architecture with justification for each major control.
- Set out a before-and-after validation approach with measurable acceptance criteria.

C. Requirements and Constraints

Functional Requirements

- A Kali Linux virtual machine dedicated to authorized security assessment.
- An isolated smart-healthcare lab network hosting representative Linux/Windows services.
- Patient-monitoring and wearable/IoMT traffic represented through the CICIoMT2024 dataset plus controlled lab traffic.
- An EHR web portal shielded by a DMZ, a WAF and HTTPS/TLS.

- Remote clinical access delivered over VPN with MFA and least privilege.
- Network segmentation split into IoMT, Clinical, Server, Management and Guest VLANs.
- Centralized IDS/IPS, logging and alert correlation.
- Backup, recovery and patch-management controls.

Tools and Technical Constraints

Tool	Purpose	Constraint
Nmap	Host discovery, port/service enumeration	Authorized lab targets only
Wireshark	Packet and protocol analysis	Captured lab/dataset traffic only
Nikto	Web-server configuration checks	Non-destructive scanning
OWASP ZAP	Web application security assessment	No destructive exploitation
Python / Jupyter	Dataset cleaning, statistics and charts	Offline/local analysis
Kali Linux utilities	Ping, ss, curl and controlled checks	No production testing

Safety and Ethics

- Testing touches only authorized, isolated laboratory addresses.
- No DoS/DDoS generation, destructive exploitation or production-system testing takes place.
- No real patient records or clinical credentials are involved.
- Captured evidence is handled as confidential laboratory material.
- Findings are reported responsibly and kept within the approved scope.

D. Proposed Smart Healthcare Security Architecture

The proposed design follows a defence-in-depth model: public-facing EHR traffic is terminated in a DMZ, while clinical systems, IoMT devices, servers and management workstations each sit in their own security zone. Traffic is allowed to cross zones only where a genuine business need exists.

Secure Smart Healthcare Centre - Defence-in-Depth Architecture

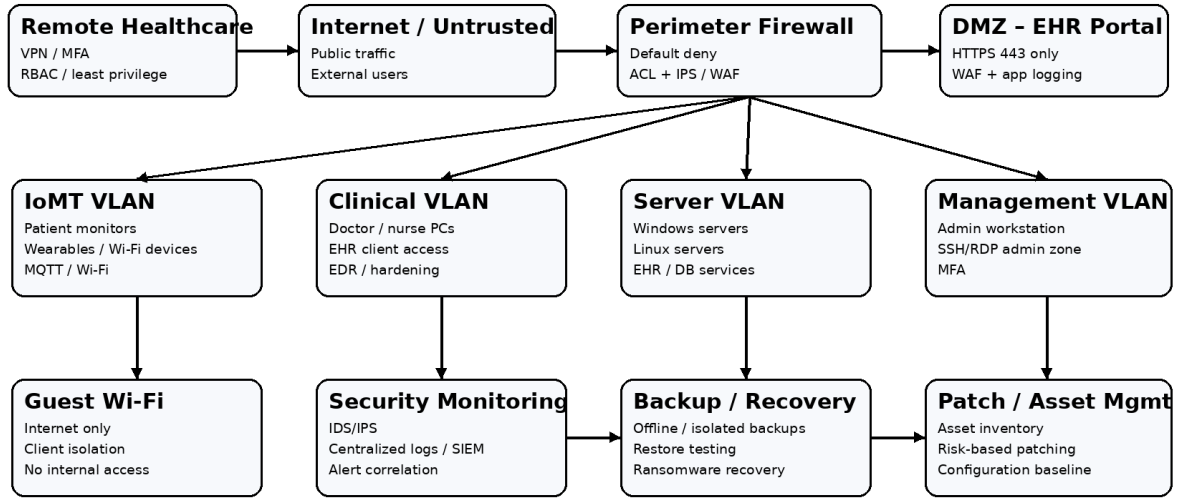


Fig. 1. Proposed defence-in-depth cybersecurity architecture for the smart healthcare centre.

Central design decision: an IoMT device must never be able to reach the database tier or the management network directly. The firewall together with inter-VLAN access-control lists enforces that separation, and IDS/IPS combined with centralized logging gives visibility across every zone.

E. CICIoMT2024 Dataset Overview

CICIoMT2024 is a benchmark dataset from the Canadian Institute for Cybersecurity built for evaluating the security of Internet of Medical Things environments. According to its official description, 18 attacks were run against an IoMT testbed of 40 real and simulated devices spanning Wi-Fi, MQTT and Bluetooth-related protocols, with the attacks grouped into DDoS, DoS, reconnaissance, MQTT and spoofing categories.

Within the Wi-Fi/MQTT portion, the data covers SYN, TCP, ICMP and UDP flood traffic; reconnaissance activity such as ping sweeps, vulnerability scans, OS scans and port scans; ARP spoofing; and MQTT-specific malformed-data plus connect/publish flood attacks. A Bluetooth Low Energy denial-of-service scenario is included as well.

The dataset ships as Bluetooth and WiFi_and_MQTT directories containing both attack and benign PCAPs plus extracted CSV features, which makes it usable for packet-level inspection as well as flow/feature-based analysis in Python or Jupyter.

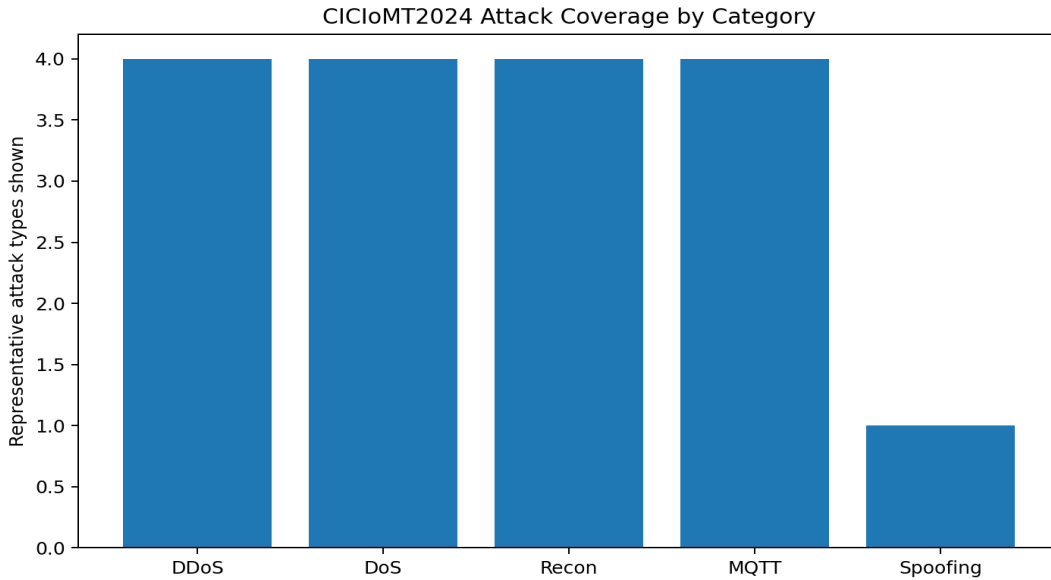


Fig. 2. Supplied CICIoMT2024 attack-coverage chart used to support the traffic-category discussion.

F. Dataset Analysis – Normal and Malicious Traffic

Normal / Benign Behaviour

Benign IoMT traffic captures the expected communication and lifecycle behaviour of connected devices. The official dataset profiles power, idle, active and interaction states, and these profiles give a reference point for spotting deviations in traffic rate, protocol usage and connection behaviour.

Malicious Behaviour Identified

Attack class	Representative behaviour	Security significance
Recon	Ping sweep, port scan, OS scan, vulnerability scan	Exposes reachable devices and services ahead of exploitation.
DoS	SYN/TCP/ICMP/UDP floods	May degrade availability of clinical and monitoring services.
DDoS	Distributed flood traffic	May saturate bandwidth and overwhelm exposed services.

MQTT	Malformed data, connect flood, publish flood	Targets the messaging layer that IoMT devices rely on.
Spoofing	ARP spoofing	May enable interception or redirection of local network traffic.

Important Traffic Indicators

- Sharp packet/flow-rate bursts relative to the established baseline.
- Large shifts in SYN, ACK, RST or connection counts.
- Repeated connection attempts toward a single service or MQTT endpoint.
- Irregular ARP activity or mismatched IP-to-MAC relationships.
- New destination ports or reconnaissance patterns absent from the normal profile.

Engineering interpretation: the dataset makes the case that no single control is sufficient for healthcare security. Reconnaissance needs to be curbed with segmentation and least privilege; floods call for rate limiting and IDS/IPS; MQTT needs authentication and protection; and spoofing risk calls for secure switching, monitoring and encrypted communication.

G. Laboratory Topology and Assessment Methodology

The hands-on validation runs inside an isolated virtual lab. The supplied screenshots show Kali Linux interacting with a Metasploitable host on the 192.168.56.0/24 network, used purely to demonstrate the authorized testing workflow rather than to represent a real production healthcare system.

Command: `ping -c 4 192.168.56.103`

Assessment Sequence

1. Confirm the target is reachable with ping.
2. Run a controlled Nmap port scan with service/version detection.
3. Review exposed services and flag unnecessary attack surface.

4. Carry out non-destructive web-server checks with Nikto and web-security checks with OWASP ZAP where applicable.
5. Capture and inspect traffic using Wireshark.
6. Analyze CICIoMT2024 normal and attack traffic in Python/Jupyter.
7. Map the findings to healthcare assets and rank the risk.
8. Apply the proposed controls, conceptually or within the isolated lab.
9. Repeat the same checks for before-and-after validation.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:73:fb:10
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:57 errors:0 dropped:0 overruns:0 frame:0
          TX packets:72 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8714 (8.5 KB)  TX bytes:6464 (6.3 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

Fig. 3. Supplied laboratory reachability / packet-testing evidence.

H. Network Security Assessment – Nmap

```
Command: nmap -sn 192.168.56.0/24
```

Nmap establishes the exposed-service baseline. The supplied screenshots capture repeated scans of the authorized lab host and illustrate the contrast between a host with visible services and one where ports are filtered or simply unresponsive.

```
Command: nmap -p- 192.168.56.102
```

Command: nmap -sV 192.168.56.103

Observed Evidence

Check	Observed result	Security interpretation
Host discovery / ping	Authorized lab host responded	Target was reachable for controlled testing.
TCP service scan	Open services identified on the lab host	Each exposed service adds to the attack surface.
Service/version detection	Older service versions visible in the supplied evidence	Patch level and configuration need review.
UDP scan	Some ports appeared filtered/no-response	Filtering reduces exposure but should still be checked against policy.

```
Session Actions Edit View Help
Status: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.00% done

kali@kali:~$ sudo nmap -p- -sS -sV 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 08:03 -0400
Status: 0:00:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 3.50% done; ETC: 08:06 (0:03:14 remaining)
Status: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 4.00% done; ETC: 08:06 (0:03:10 remaining)
Status: 0:00:12 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 4.50% done; ETC: 08:06 (0:03:12 remaining)
Status: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 5.00% done; ETC: 08:06 (0:03:10 remaining)
Status: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 5.50% done; ETC: 08:06 (0:03:12 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.0050s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
5800/tcp  open  slp
5801/tcp  open  slp-tls

Nmap done: 1 IP address (1 host up) scanned in 69.45 seconds

kali@kali:~$ sudo nmap -p- -sS -sV 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 08:04 -0400
Nmap scan report for 192.168.56.102
Host is up (0.024s latency).

PORT      STATE SERVICE VERSION
5800/tcp  open  slp?
5801/tcp  open  slp-tls?

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 147.42 seconds

kali@kali:~$ sudo nmap -p- -sS -sV -p 135,139,445,3389,5985,5986,22 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 08:07 -0400
Nmap scan report for 192.168.56.102
Host is up.

PORT      STATE SERVICE VERSION
22/tcp    filtered ssh
135/tcp    filtered wsrpc
```

Fig. 4. Supplied Nmap service/port scanning evidence.

Non-destructive Web Checks

Tool	Purpose	Evidence / expected observation
Nikto	Identify outdated components, missing headers and exposed resources	Supplied evidence shows web-server configuration weaknesses and outdated components.
OWASP ZAP	Passive/controlled web application security assessment	Supplied practical evidence includes a missing anti-clickjacking header finding.
curl	Inspect HTTP response headers	Useful for confirming HTTP/HTTPS status and security headers.

```

kali@kali:~$ nmap -ss scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-10 06:56 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0001s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Nmap done: 1 IP address (1 host up) scanned in 8.34 seconds

kali@kali:~$ nmap -ss scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-10 06:57 EDT
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0021s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 986 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    closed domain
80/tcp    open  http
139/tcp   closed netbios-ssn
143/tcp   closed imap
161/tcp   closed snmp
443/tcp   closed https
580/tcp   closed isakmp
993/tcp   closed imaps
3389/tcp  closed ms-wbt-server
5860/tcp  open  sip
5861/tcp  open  sip-tls
8080/tcp  closed http-proxy
8081/tcp  closed blackice-icecap

Nmap done: 1 IP address (1 host up) scanned in 104.31 seconds

kali@kali:~$ nmap -sv scanme.nmap.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-10 06:59 EDT
Stats: 0:00:49 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Ping Scan Timing: About 100.00% done; ETC: 06:59 (0:00:00 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.0059s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http        Apache httpd 2.4.7 ((Ubuntu))
139/tcp   closed netbios-ssn
143/tcp   closed imap
443/tcp   closed https
3389/tcp  closed ms-wbt-server
5860/tcp  open  sip7
5861/tcp  open  sip-tls7
8080/tcp  closed http-proxy

```

Fig. 6. Supplied Nikto web-server assessment evidence.

Recommended EHR Web Controls

- Enforce HTTPS/TLS for all authentication and patient-data traffic.
- Apply a WAF and a default-deny firewall policy for public requests.
- Use secure, HttpOnly and SameSite session cookies.

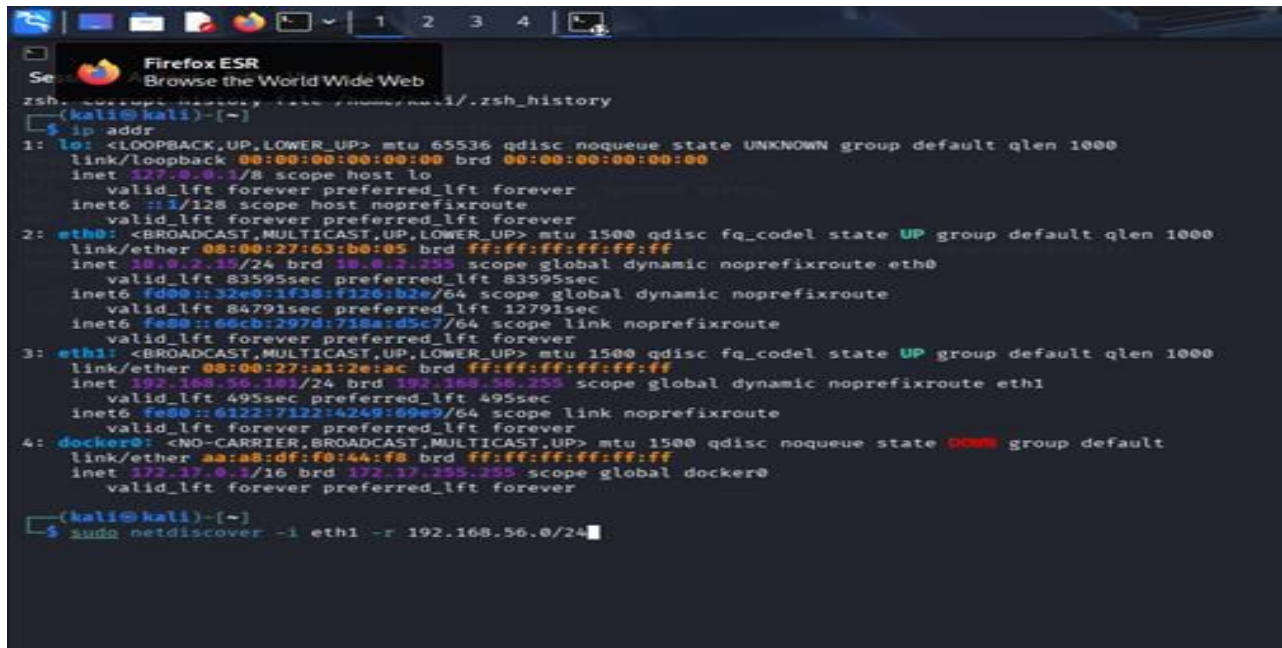
- Apply server-side authorization and RBAC to every protected function.
- Use parameterized database queries and validate all input.
- Add CSP, X-Content-Type-Options and anti-clickjacking headers.
- Store uploaded files outside executable web directories and validate type/size/content.

J. Packet Analysis – Wireshark

Wireshark is used to check whether the observed traffic looks normal, suspicious or improperly exposed. Within the healthcare architecture, packet inspection is particularly useful for confirming that sensitive application traffic stays encrypted and that unexpected protocols are not crossing security boundaries.

Analysis Approach

- Filter by protocol — tcp, udp, mqtt, arp, http and tls.
- Compare packet rates and connection patterns against the normal CICIoMT2024 baseline.
- Flag repeated SYN/connection attempts associated with flood behaviour.
- Inspect ARP activity for unexpected IP-to-MAC changes.
- Confirm sensitive EHR traffic travels over encrypted TLS rather than plaintext HTTP.



```

(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 83595sec preferred_lft 83595sec
    inet6 fd00::32e0:1f38:f126:b2e/64 scope global dynamic noprefixroute
        valid_lft 84791sec preferred_lft 12791sec
    inet6 fe80::66cb:297d:718a:d5c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a1:2e:ac brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 495sec preferred_lft 495sec
    inet6 fe80::6122:7122:4249:69e9/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether aa:a8:df:f0:44:f8 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ sudo netdiscover -i eth1 -r 192.168.56.0/24
  
```

Fig. 7. Supplied packet-analysis evidence from the laboratory workflow.

Validation criterion: once hardened, sensitive EHR credentials and patient-data requests should not be visible as plaintext application payloads, and monitoring should catch unusual bursts and protocol deviations without disrupting normal clinical traffic.

K. Wireless and Operating-System Security Assessment

Wireless / IoMT Network

The IoMT wireless segment should run WPA2-Enterprise or WPA3 with enterprise authentication wherever the devices support it. IoMT devices belong on a dedicated VLAN with only the minimum network access their clinical function requires, and guest Wi-Fi must stay fully isolated from clinical and server networks.

- Disable insecure legacy wireless protocols and weak shared credentials.
- Use separate SSIDs/VLANs for IoMT, clinical users and guests.
- Apply certificate-based or enterprise authentication for managed devices where feasible.
- Enable client isolation on the guest wireless network.
- Monitor for rogue devices, unexpected associations and ARP anomalies.

Windows and Linux Servers

Area	Control
Exposed services	Disable unnecessary services and restrict required ports with host firewall rules.
Remote administration	Allow SSH/RDP only from the Management VLAN or an approved VPN.
Authentication	Enforce MFA for administrative and remote healthcare access.
Patching	Apply security updates according to asset criticality and risk.
File sharing	Restrict SMB/NFS shares to named users and required hosts.
Endpoint monitoring	Use EDR/host logs and forward security events to centralized monitoring.

```

Session / Terminal Emulator
Use the command line

SSH-2.0-OpenSSH_7.6p1 Ubuntu-7.6p1
^C

(kali@kali)~$ nc -v 192.168.56.102 80
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 80 (http) open
GET / HTTP/1.0

HTTP/1.1 200 OK
Date: Tue, 11 Aug 2020 04:59:44 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html

<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>

  NETWORK
  1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36 37 38 39 40 41 42 43 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91 92 93 94 95 96 97 98 99 100

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

</pre>
<ul>
<li><a href="/twiki/">Twiki</a></li>
<li><a href="/phpMyAdmin/">phpMyAdmin</a></li>
<li><a href="/mutillidae/">Mutillidae</a></li>
<li><a href="/dvwa/">DVWA</a></li>
<li><a href="/dav/">WebDAV</a></li>
</ul>
</body>
</html>

(kali@kali)~$ nc -v 192.168.56.102 25
192.168.56.102: inverse host lookup failed: Unknown host
(UNKNOWN) [192.168.56.102] 25 (smtp) open
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)

```

Fig. 8. Supplied laboratory evidence showing a Linux-based Metasploitable environment used for authorized testing.

L. Risk Register and Prioritization

Risk priority is driven by likelihood combined with impact on confidentiality, integrity, availability and patient safety. High-impact availability attacks are treated as especially serious because interrupting patient monitoring or clinical access carries real operational consequences.

Priority	Risk / Finding	Likelihood	Impact	Treatment
1 – Critical	DDoS/DoS against exposed EHR or IoMT services	High	High	Segmentation, rate limiting, IDS/IPS, upstream protection.
2 – High	Unnecessary exposed network services	High	High	Default-deny firewall and service minimization.

3 – High	MQTT connect/publish flood or malformed traffic	Medium–High	High	Broker authentication, ACLs, TLS and anomaly detection.
4 – High	ARP spoofing on the local IoMT network	Medium	High	Protected switching, segmentation, monitoring and secure management.
5 – High	Weak EHR authentication or access control	Medium	High	MFA, RBAC, session security and least privilege.
6 – Medium-High	Outdated Windows/Linux components	Medium	High	Risk-based patch management and configuration baselines.
7 – Medium	Guest/IoMT wireless isolation failure	Medium	High	Separate VLANs, WPA2-Enterprise/WPA3 and ACLs.
8 – Medium	Insufficient centralized logging	Medium	Medium	SIEM, time synchronization and alert correlation.

Risk Treatment Principle

The architecture does not try to eliminate every risk outright. Instead it lowers the probability of compromise, limits how far an attacker can move laterally, improves the odds of catching an attack in progress, and strengthens recovery for the cases where prevention fails.

M. Implemented / Proposed Security Controls

Network Segmentation and Firewall

- Internet → Firewall/WAF → EHR DMZ: permit HTTPS 443 only unless another service has an explicit justification.
- IoMT VLAN → Server VLAN: permit only approved clinical protocols and destinations.
- Clinical VLAN → EHR services: permit only the required application traffic.

- Management VLAN → infrastructure: permit administration protocols only from approved administrator devices.
- Guest Wi-Fi → Internet: deny all internal VLAN access.
- Apply a default-deny inter-VLAN policy with explicit logging for blocked traffic.

Identity and Access Control

- MFA for remote healthcare access and privileged administration.
- RBAC covering doctors, nurses, technicians, administrators and support staff.
- Least privilege and separation of duties for high-risk operations.
- Automatic session timeout and secure credential storage.

Encryption

- TLS for EHR web traffic and approved API connections.
- TLS/authentication for MQTT wherever supported.
- Encrypted backups with protected key management.
- Secure VPN tunnels for remote healthcare access.

N. IDS/IPS, Logging, Patch Management and Recovery

Intrusion Detection and Centralized Logging

Control	Implementation objective	Validation
IDS/IPS	Detect scans, floods, spoofing and abnormal IoMT traffic	Replay/observe controlled attack patterns and measure the detection rate.
Centralized logging	Collect firewall, server, EHR, VPN and IoMT security events	Verify event timestamps, source and correlation.
Alert correlation	Combine multiple related events into a single incident	Measure false alarms and response time.

Time synchronization	Use a common trusted time source	Check that timestamps stay consistent across devices.
----------------------	----------------------------------	---

Patch and Asset Management

- Maintain an inventory of every IoMT device, workstation, server and network component.
- Classify assets by clinical criticality and exposure.
- Apply security patches according to risk and vendor support status.
- Maintain secure configuration baselines and review drift.
- Replace unsupported software or isolate it behind compensating controls.

Backup and Recovery

- Keep offline/isolated backups of critical EHR and configuration data.
- Encrypt backup data and restrict who can administer backups.
- Test restoration regularly rather than assuming backups will work.
- Maintain recovery priorities for EHR, authentication, monitoring and network services.
- Document recovery procedures for ransomware or major availability incidents.

O. Before-and-After Validation Plan

The supplied screenshots establish the pre-hardening laboratory evidence. Post-hardening figures still need to be captured by repeating the same checks once the relevant controls are configured. The table below keeps the observed baseline evidence separate from the target acceptance criteria — it does not claim any post-remediation measurements that were not actually taken.

Parameter	Before / baseline evidence	After target / acceptance criterion
Exposed services	Nmap shows multiple reachable services in the lab evidence.	Only required services remain reachable; unnecessary ports are closed or filtered.
Recon detection	Dataset contains recon behaviours such as ping sweep and port scan.	IDS/IPS detects $\geq 90\%$ of controlled recon events with acceptable false alarms.
Attack-detection rate	Baseline detection depends on the monitoring available.	Target $\geq 90\%$ for the selected controlled attack patterns.

False alarms	To be measured from benign replay/baseline traffic.	Target $\leq 10\%$ for the defined test set.
Response time	Not yet measured from the supplied screenshots.	Target alert generation within an agreed operational threshold, e.g. < 60 s.
Network availability	Baseline measured during normal lab traffic.	Maintain $\geq 99\%$ availability during non-destructive validation.
Resource utilization	Baseline CPU/memory/network use should be recorded.	Security controls should not add unacceptable resource overhead.

Repeatable Validation Workflow

1. Record a baseline port/service inventory with Nmap.
2. Replay a controlled benign sample plus selected CICIoMT2024 attack patterns.
3. Record IDS/IPS alerts, timestamps and classification.
4. Repeat the Nmap and service checks after controls are applied.
5. Compare detection rate, false alarms, response time, availability and resource utilization.
6. Document the evidence with screenshots and retain raw logs for reproducibility.

P. Engineering Justification and Trade-offs

Why Segmentation?

Segmentation limits how far an attacker can move laterally. If a wearable or patient-monitoring device is compromised, that compromise should not automatically open a path to the EHR database or the management systems. The cost is extra network configuration and ongoing monitoring effort.

Why MFA + RBAC?

Healthcare systems hold high-value information and privileged functions. MFA blunts the impact of a stolen password, and RBAC bounds what any given role is able to do. The cost is added authentication friction and identity-management overhead.

Why IDS/IPS + Centralized Logging?

Prevention alone can't guarantee security. Detection gives visibility into reconnaissance, floods, spoofing and abnormal IoMT behaviour, and centralized logs support incident investigation afterward. The cost is storage, tuning effort and false-alarm management.

Q. Limitations and Possible Improvements

Limitations

- The supplied practical screenshots mainly demonstrate an authorized Linux/Metasploitable lab workflow rather than a complete smart-healthcare production environment.
- The screenshots don't provide a full post-remediation measurement set, so the after-values in this report are stated as validation targets rather than claimed experimental results.
- No direct destructive exploitation, DoS execution or real patient-data testing was performed.
- The supplied evidence doesn't experimentally establish every possible Windows, wireless or EHR vulnerability.
- CICIoMT2024 is a benchmark dataset and can't represent every hospital topology, vendor implementation or clinical workflow.

Possible Improvements

- Run the full CICIoMT2024 PCAP/CSV analysis in Jupyter with class counts, flow-rate distributions and protocol comparisons.
- Build a reproducible IDS evaluation over selected benign and malicious subsets and report a confusion matrix with precision, recall and F1-score.
- Add a dedicated wireless testbed to validate WPA2-Enterprise/WPA3 and IoMT isolation.
- Deploy a small SIEM stack and measure end-to-end alert latency.
- Automate configuration checks and patch-status reporting for Windows and Linux servers.
- Run scheduled backup restoration drills and document recovery time objectives.

R. Conclusion

This solution builds a secure smart healthcare centre around defence in depth. It separates the IoMT, clinical, server, management and guest networks; places the EHR portal behind a protected

DMZ; applies default-deny firewall rules; requires MFA and RBAC for sensitive access; protects communications with encryption; watches network behaviour through IDS/IPS and centralized logging; and strengthens resilience through patch management, isolated backups and recovery testing.

CICIoMT2024 offers a realistic healthcare-IoT security baseline because it captures both benign/profiling traffic and several malicious classes — DDoS, DoS, reconnaissance, MQTT and spoofing — across Wi-Fi, MQTT and Bluetooth-related environments. The practical Kali Linux evidence backs the assessment workflow through reachability checks, Nmap scanning, web-server checking and packet analysis.

The key engineering takeaway is that healthcare security has to be treated as a system-level problem. Cutting down exposed services, isolating IoMT devices, securing identity, watching for abnormal traffic, and preparing for recovery together provide stronger protection than any single tool could. The before-and-after validation plan defined here means the finished implementation can be judged on measurable evidence rather than assumptions.

Student Reflection

This assignment helped me connect CICIoMT2024 traffic analysis, ethical-hacking testing and secure healthcare architecture into one picture. I learned how network and web vulnerabilities get identified and then translated into practical security controls, and the project sharpened my hands-on understanding of Nmap, Wireshark, Nikto, network segmentation, access control, MFA, encryption and intrusion detection.

I also learned how to validate security improvements against measurable parameters — attack detection, response time, exposed services and network availability. Altogether, this work strengthened my practical cybersecurity skills and my understanding of secure healthcare systems.

S. References

- [1] S. Dadkhah, E. C. P. Neto, R. Ferreira, R. C. Molokwu, S. Sadeghi, and A. A. Ghorbani, "CICIoMT2024: Attack Vectors in Healthcare Devices—A Multi-Protocol Dataset for Assessing IoMT Device Security," *Internet of Things*, vol. 28, Art. no. 101351, Dec. 2024.
- [2] M. Fagan, K. N. Megas, J. Marron, K. G. Brady, B. B. Cuthill, R. Herold, D. Lemire, and N. Hoehn, *IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements*, NIST Special Publication 800-213, National Institute of Standards and Technology, Nov. 2021.
- [3] K. N. Megas, M. Fagan, J. Marron, K. G. Brady, B. B. Cuthill, R. Herold, D. Lemire, and N. Hoehn, *IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog*, NIST Special Publication 800-213A, National Institute of Standards and Technology, Nov. 2021.
- [4] National Institute of Standards and Technology, *Securing Wireless Infusion Pumps in Healthcare Delivery Organizations*, NIST Special Publication 1800-8, National Cybersecurity Center of Excellence, 2018.
- [5] OWASP Foundation, *OWASP Web Security Testing Guide, Version 4.2*, OWASP Foundation, 2020.
- [6] R. Pulivarti, K. Littlefield, S. Wang, B. Patrick, and R. Williams, *Mitigating Cybersecurity and Privacy Risks in Telehealth Smart Home Integration*, NIST Cybersecurity White Paper CSWP 34, National Institute of Standards and Technology, Dec. 2025.